

Topic: Technical Migration Failure, Operational Failure, and Business Continuity Crisis

The TSB Bank Migration Failure (2018)

BC/DR Analysis – By: Shi Hao Guo

Scenario Background:

In April 2018, TSB Bank, a major retail bank in the United Kingdom, attempted a migration of its 5.2 million customers and £30 billion worth of deposits to a new banking platform. TSB had previously been using the IT systems of its former parent company, Lloyds Banking Group, and this migration was essential to complete its separation.

The new platform, called "Proteo4UK," was built by its Spanish owner, Sabadell. The migration involved moving 1.3 billion records and transferring all customer data and core banking functions over a weekend shutdown period. The migration plan was extensive, relying on the systems being fully operational for customers by Monday morning.

The Crisis and Business Impact:

The system of transfer was deemed a success by TSB leadership over the weekend. However, as customers began accessing the new platform on Monday, April 23, 2018, the systems immediately failed.

The Outage Included:

- **Service Disruption:** Thousands of customers have been locked out of their online and mobile banking accounts for weeks. Customers could not check balances, pay bills, or transfer money.
- **Operational Failure:** TSB branches and call centers were overwhelmed and often had no more information than the customers themselves, leading to massive backlogs and reputational damage.
- **Technical Failure:** When some accounts did become accessible, they displayed incorrect balances, showed other customers' personal data, or allowed transfers to incorrect accounts. The core system architecture was unstable, leading to a long and complicated restoration process.
- **Duration & Cost:** The total system disruption lasted several weeks, with the bank spending over £330 million in recovery costs, fraud reimbursement, and compensation. The CEO later resigned.

The TSB Bank Migration Failure (2018):

The subsequent independent investigation found that TSB and Sabadell failed to understand the scale and complexity of the required testing for the new platform and that the "testing was not Good enough." There was no adequate plan for a complete system fail-back or for managing the Integrity of the migrated data in case of mass failure. Your team is a third-party consulting firm hired by TSB's board of directors in June 2018 to perform a post-mortem Business Continuity and Disaster Recovery (BC/DR) analysis.

Business Impact Analysis & Recovery Objectives

The Two Most Critical Business Functions

The BIA determines important business activities and recovery objectives such as the RTO, RPO, and MTD (calculated as $RTO + WRT$). In the case of TSB, the two most important functions were:

Function 1: Online and Mobile Banking Access

If the system is not functioning properly, customers will not be able to view their balances or log into their account, and consequently, the Availability requirement of the CIA security model will be compromised.

RTO: Two hours (MTD 4 hours and WRT 2 hours).

RPO: Fifteen minutes.

Function 2: Funds Transfer and Payment Processing

This system facilitates bill payments, fund transfers, and other transactions; interruptions will lead to financial losses, compliance issues, and delays in payments.

RTO Recommendation: 4 hours (Tier 1 application).

RPO Recommendation: 0 data loss, necessitating synchronous replication.

What TSB Actually Achieved

The real-time TSB recovery point objective was negative because there were wrong balances, and customer details were exposed to other customers.

In conclusion, it can be noted that TSB did not comply with recovery time objectives and data integrity requirements, unlike well-known banks, which had their recovery time objectives and recovery point objectives strategies, and which managed to recover from disasters much quicker than TSB.

Risk Mitigation Strategy and Plan Development

TSB's One-Way Migration Was a Risk Acceptance Failure

There're four risk mitigation approaches: Acceptance, Avoidance, Limitation, and Transference. The non-reversibility nature of the migration by TSB is an example of risk acceptance, which has low initial costs but high costs if the risk occurs, hence a grave mistake when migrating 1.3 billion records.

However, an effective risk mitigation strategy would require the following fail-back actions before going live:

- **Parallel Operation Phase:**
 - Operate the existing Lloyds system alongside Proteo4UK for 30 to 60 days and compare transactions to identify errors prior to shutting down the system.
 - This phase entails minimizing risk by gradually phasing out the existing system.
- **Back-Out Plan Documentation and Fail-Back Recovery Time Objective (RTO):**
 - A process of reverting back all data from the new system to the old one.
 - It should include an RTO for fail-back, such as 4 hours, a person responsible for executing the fail-back, and a legacy environment prepared for receiving data.
- **Hot Standby Recovery Plan of the Legacy System:**
 - Have an already installed and in-sync copy of the old Lloyds system during migration, thus allowing instant fallback without any holdups from vendor support or resource procurement.
- **Sign Off by Change Advisory Board (CAB):**
 - Go-live will not occur until the CAB sign-off on back-out test, attainable fail-back RPO, and trigger points defined for communicating to recovery groups.

Two Critical Missing Sections in TSB's ITDR Plan

The report highlights that TSB lacks a proper fail-back plan. Nonetheless, from the ITDR Plan Development Framework in Chapter 7, two important elements are obviously absent in TSB's strategy.

Area 1: Activation Triggers and Disaster Level Classification

An ITDR strategy requires explicit activation criteria. For TSB, the management deemed the launch of production a success without any actual customer load and had no activation criteria (such as “activate when the number of authentication errors exceeds x% in 2 hours after the launch”).

Moreover, there was no Disaster Level Classification, where small, medium, and major disasters have been identified. However, for TSB, a major disaster was considered a small one. This lack of an escalation process made it impossible to take proper action.

Area 2: Data Integrity Verification and Catch-Up Processing

The ITDR model needed catch-up processing, which was not there with TSB. Furthermore, the verification of the 1.3 billion records that were migrated from the legacy system was missing.

Moreover, lack of workarounds was another significant gap. The role of the workaround is to maintain essential functions despite the failure in the system, which could not be done by TSB.

Emergency Response and Testing/Auditing

Emergency Response Failures and What Should Have Happened

As per rule number one, the emergency response process should be simple because complex actions are hard to perform at the time of emergencies. The response given by TSB on 23 April was not according to the rules, since it did not activate either CMT or CCP, nor did it use any alternate customer services.

Within the first 24 hours, these three actions should have been activated:

1. Single Spokesperson and Honest Public Communication

- Chapter 8 provides three rules for managing crisis communications:
 - Speak the truth, assign one person as the spokesperson, and address the who, what, when, where, why, and how.
 - These principles were ignored in the TSB case.
- The Media Relations Team would have been responsible for issuing a holding statement that admits the problem and promises continued reporting without any assurances of when service will be restored.

2. Manual Workarounds and Alternative Service Channels

- ITDR Plan Appendices shall contain documentation of manual workarounds in case of system downtime.
- TSB should have allowed its branches to reconcile their accounts based on their latest records, waive penalty charges during the downtime, notify customers through text messages or emails, and give them access to cash via ATMs through partner banks.

3. Internal Staff Communication

- The branch's employees had no instructions on how to inform the customers of the problem.
- In the event of the system failure, the CMT should have notified its employees using an internal messaging service within 30 minutes.
- It should have provided them with a set script, escalation of phone numbers, and status updates.

What Testing TSB Should Have Done

The investigation revealed that 'the tests were not adequate. There's four methods of testing, ranging from least to most intrusive. It seems that TSB did not do any of these tests properly:

Test Type	Disruption Level	What It Covers	TSB Status
Paper Walk-Through	Minimal	Plan logic review	Not performed
Functional Exercise	Moderate	Specific procedures	Not performed
Field Exercise	High	Realistic simulation	Not performed
Full Interruption Test	Maximum	Live systems, alt sites	Not performed

At minimum, TSB needed these three specific tests before the migration weekend:

Full Interruption Test on the Integrated System

Full Interruption Testing triggers the alternate path and disrupts the live systems. In case of TSB, it would have included conducting partial migrations (like 5-10% of customer data) in a full production environment. It would have helped identify integrity problems, wrong balances, and cross-customer data exposure before going live with actual customer records.

Load and Stress Testing

TSB would have had to ensure that Proteo4UK could handle 5.2 million simultaneous users, especially in times when usage is expected to be at its highest, for example, on a Monday morning. BC/DR systems should always be tested in terms of their required performance level.

Data Integrity Audit

The definition of IT audit as a structured verification process regarding criteria set out for the audit. Following each migration test process, TSB must have checked all migrated records against Lloyds' original data. This would mean that all account balances and transactions should be tallied perfectly.

Discussion Questions

Question 1:

Should corporations be obligated to approach a large-scale migration of systems as seriously as they approach disaster recovery?

Question 2:

Would the resignation of the CEO be appropriate, or is this simply a way to avoid addressing the real issues?

Question 3:

If TSB had approached the migration process as a disaster from the very beginning, do you believe there would be an outage?

Conclusion

Consequently, the failure of TSB can be attributed to several lapses because most of the BC/DR functions have been ignored. The absence of BIA, RTO/RPO definition, test fail back, trigger, validation, and emergency communication plans is evident.

The approach shows what needs to be done to avoid such situations. The recovery cost of £330 million and the effect on 5.2 million customers show the repercussions of ignoring BC/DR planning.